

Grounding Reduces Citation Hallucination in Multimodal LLM Zero-Shot Classification of IoT-Botnet Traffic

[TO FILL IN]

[Affiliation(s) TO FILL IN]

STATUS: FULL-SCALE DRAFT. This draft uses the complete 34-class CIC-IoT-2023 experiment (510 Claude API calls: 34 classes $\times$ 5 samples/class $\times$ 3 prompting conditions; baseline detectors evaluated at $n=40$ /class, 1,360 rows). Every CVE/CAPEC identifier discussed as “verified” in this draft was independently checked against nvd.nist.gov or capec.mitre.org during the drafting session — 21 distinct reference IDs in total, zero of which were found to be fabricated (non-existent). A residual 28–30 citations per ungrounded condition remain **not yet individually verified** against MITRE and are reported honestly as such (Sections 4.2 and 5). Before arXiv submission: (1) complete verification of the remaining ~ 28 unverified reference IDs per condition; (2) resolve the LLM/baseline sample-size mismatch ($n=5$ /class vs. $n=40$ /class) by scaling the Claude harness to $n=40$ /class; (3) fill remaining **[VERIFY]** bibliographic placeholders; (4) add author/affiliation information.

Abstract

Multimodal large language models (LLMs) have recently shown promise for zero-shot network intrusion detection by reasoning over visualized traffic, but prior work has not evaluated whether these models’ stated justifications are factually grounded — a real concern given documented hallucination rates in LLM-generated cyber threat intelligence (CTI), and a gap that is particularly unaddressed for IoT-specific botnet traffic. We study this question on the full 34-class CIC-IoT-2023 dataset, evaluating a multimodal LLM (Claude Sonnet 5) in a zero-shot setting to classify time-windowed traffic visualizations under three prompting conditions: naive (no external grounding), text-grounded (the model is instructed to cite a supporting CVE/CAPEC reference from its own knowledge), and retrieval-augmented (RAG; real MITRE CAPEC/NVD CVE records are retrieved and injected into the prompt, and the model is instructed to cite only from that material). Across 510 classification calls (5 samples/class $\times$ 34 classes $\times$ 3 conditions), classification accuracy was 99.4% (naive), 98.8% (text-grounded), and 100% (RAG); the handful of misses in the ungrounded conditions were traced to a data-parsing artifact (truncated single-character responses), not model reasoning failures. We manually audited the model’s cited references against the authoritative CAPEC/NVD record. Across 21 distinct reference IDs checked, **we found zero fabricated (non-existent) identifiers in any condition, including the fully ungrounded naive condition** — the model never invented a CAPEC or CVE number. However, citation *correctness* degraded substantially without grounding: 35% of naive-condition citations and 29% of text-grounded citations referenced a real but wrong-family attack pattern (e.g., citing CAPEC-98, “Phishing,” with an invented description to justify an RST/FIN flood), compared to 0% wrong-family-with-fabricated-description citations under RAG grounding, where the model was additionally observed to correctly decline to cite (respond “N/A”) for 41% of attack samples outside the scope of the retrieved reference set — direct evidence that retrieval constraints suppress out-of-scope citation rather than merely improving citation quality on covered classes. We additionally compare against two classical statistical baselines (rolling z-score, Isolation Forest) evaluated at $n=40$ /class; both collapse sharply on non-volumetric attack categories (Isolation Forest recall: 97.5% on flooding attacks vs. 3.6% on web-layer attacks such as SQL injection and XSS, 2.5% on brute-force, 17.5% on spoofing/MITM), while the LLM classifies

these same categories with near-perfect accuracy in every condition — reframing the LLM’s advantage away from raw binary detection (where a tuned classical baseline is competitive on volumetric attacks) and toward multi-class, cross-category attack identification paired with an explanation whose *specificity* and *correctness*, not mere existence, is measurably improved by retrieval grounding.

1 Introduction

The Internet of Things (IoT) has become a primary vector for large-scale botnet attacks, most notably demonstrated by the 2016 Mirai botnet, which compromised hundreds of thousands of poorly-secured devices via default-credential exploitation and was used to launch record-setting distributed denial-of-service (DDoS) attacks [Antonakakis et al., 2017, Koliadis et al., 2017]. Detecting and explaining such attacks in real time remains difficult: classical statistical and machine-learning anomaly detectors can flag deviations from normal traffic but, as we show in Section 3.6, their sensitivity is highly uneven across attack categories — strong on volumetric floods, weak-to-nonexistent on reconnaissance, credential, and application-layer attacks — and none of them identify *which* technique is occurring or *why*. Manual analyst triage does not scale to modern traffic volumes.

Recent work has shown that multimodal LLMs can perform zero-shot network intrusion detection by reasoning over visualized NetFlow traffic [VERIFY] full citation — IEEE paper, “Multimodal LLMs for Zero-Shot Intrusion Detection Using NetFlow Visualisations”, evaluating GPT-4o and LLaVA on traffic visualizations augmented with manually injected DoS/DDoS/IP-sweep attacks. This line of work is promising precisely because it pairs detection with a natural-language explanation — but no prior work has asked whether that explanation is *true*. This matters because LLM-generated cyber threat intelligence has been shown to hallucinate at measurable, non-trivial rates, including fabricating CVE identifiers that do not exist and misstating technical details of real vulnerabilities [VERIFY] full citation — “HalluCVE: A Multi-Signal Benchmark for Hallucination Detection in LLM-Generated Cyber Threat Intelligence”. Retrieval-augmented generation (RAG) has been proposed as a mitigation for vulnerability-analysis hallucination in text-only settings [VERIFY] full citation — “ProveRAG: Provenance-Driven Vulnerability Analysis with Automated Retrieval-Augmented LLMs”, but this has not been tested in a multimodal, IoT-specific setting, nor at the scale of a full, diverse attack taxonomy.

This paper makes four contributions:

1. We extend zero-shot multimodal traffic classification to the full 34-class CIC-IoT-2023 taxonomy — DDoS/DoS floods, fragmentation attacks, Mirai botnet variants, reconnaissance, web-application attacks, spoofing, and brute force — a scope not covered by prior work, which used generic, non-IoT traffic with a small number of injected attack types.
2. We introduce three prompting conditions and measure not just classification accuracy but *citation quality*, via a manually verified taxonomy (fabricated / real-but-generic / real-but-wrong-family / real-and-correct) checked directly against MITRE CAPEC and NVD records rather than trusting the model’s own claims of correctness.
3. We show that retrieval grounding’s benefit is not only “more correct citations” but also “fewer out-of-scope citations” — the model correctly withholds a citation when the retrieved material does not cover the observed attack, a distinct and arguably more important safety property than citation accuracy alone.
4. We compare the LLM’s performance against two classical statistical baselines across the full attack taxonomy, showing that baseline performance is highly attack-category-dependent in a way that a small-scale (e.g., DDoS-only) evaluation would not reveal, clarifying where the LLM’s actual advantage lies.

2 Related Work

Zero-shot multimodal intrusion detection. [VERIFY] full citation visualized time-windowed NetFlow data as scatter plots and evaluated GPT-4o and LLaVA in a zero-shot setting on generic traffic with injected DoS/DDoS/IP-sweep attacks, finding that GPT-4o in particular could detect structural anomalies from visual patterns alone. This paper is the direct precedent for our visualization-based classification approach; our contribution extends it to IoT-specific botnet traffic across a full 34-class taxonomy and adds the hallucination/citation-grounding dimension it did not address.

LLM hallucination in cyber threat intelligence. [VERIFY] full citation, HalluCVE introduced a benchmark for hallucination in LLM-generated CTI using a four-component scoring approach (entailment, lexical alignment, LLM-as-judge, cross-model consensus), finding hallucination index values from 0.48–0.82 across models, and near-total fabrication when models were queried about CVEs disclosed after their training cutoff. Our hallucination/citation-quality scoring (Section 3.5) is methodologically inspired by this work but adapted to a single-model, multimodal setting, and — as discussed in Section 5 — our results suggest a refinement to the “fabrication” framing: on this task, the dominant failure mode was not ID fabrication but confident misattribution of real reference material.

Retrieval-augmented grounding for vulnerability analysis. [VERIFY] full citation, ProveRAG proposed retrieval-augmented grounding for vulnerability analysis to reduce hallucination in text-only LLM outputs. We apply the same principle — retrieving real reference material at inference time rather than relying on parametric knowledge — to a multimodal classification task, and additionally measure a second RAG benefit beyond citation accuracy: suppression of out-of-scope citation when the retrieved corpus does not cover the observed technique.

IoT botnet traffic datasets. The CIC-IoT-2023 dataset [Neto et al., 2023] provides labeled traffic from 33 attacks across 7 categories (including Mirai and DDoS variants) captured from a 105-device IoT topology, and is the data source for this study; we use all 34 provided labels (33 attack classes plus Benign).

The Mirai botnet. Antonakakis et al. [Antonakakis et al., 2017] provide a retrospective analysis of Mirai’s growth and DDoS activity; Koliass et al. [Koliass et al., 2017] analyze the broader class of IoT-botnet DDoS attacks Mirai popularized.

3 Methodology

3.1 Dataset and Sampling

We use all 34 class labels present in the CIC-IoT-2023 CSV export: `BenignTraffic` and 33 attack classes spanning DDoS/DoS floods (TCP, UDP, HTTP, ICMP, SYN, PSHACK, RSTFIN, SlowLoris, SynonymousIP), fragmentation attacks (ACK, ICMP, UDP), the three Mirai botnet variants present in the dataset (`Mirai-greeth_flood`, `Mirai-greip_flood`, `Mirai-udpplain`), reconnaissance (host discovery, OS scan, ping sweep, port scan), web-application attacks (SQL injection, XSS, command injection, file upload, browser hijacking, backdoor malware, vulnerability scan), spoofing (DNS spoofing, ARP spoofing/MITM), and dictionary brute force. Each row in the source CSVs is a pre-aggregated flow-level feature vector summarizing approximately 100 packets (rate, TCP flag composition, protocol mix, packet-size statistics, inter-arrival time; 39 features total, no IP-address fields). Classes with more than one CSV part file are sampled proportionally across their part files rather than concatenated in memory. We group consecutive rows into windows of 30 (a “sample”) and randomly select samples per class: **5 samples/class (170 total) for the Claude harness**, and **40 samples/class (1,360 total) for the two non-LLM baseline detectors**. This sample-size mismatch is a real limitation of the current draft (Section 5) — it exists because the LLM harness incurs per-call API cost and latency that the baselines do not, and this pilot prioritized full

34-class coverage at a defensible LLM sample size over matched- N precision. It should be resolved before submission by scaling the LLM harness to $n=40/\text{class}$.

3.2 Visualization

Each sample is rendered as a four-panel time-series image: (1) packet rate, (2) TCP flag composition, (3) protocol mix (stacked area), (4) average and standard-deviation packet size, across the 30 windows in the sample. **Methodological note:** the prior work we extend visualized host-communication structure via IP-address scatter plots; the CIC-IoT-2023 CSV export used here contains no IP fields, so this is not reproducible from this data source. We substitute a multi-panel flow-feature time series as a documented deviation.

3.3 Prompting Conditions

All three conditions show the model the same image and ask it to classify the traffic into one of the 34 class labels, in a fixed response format (classification, reference ID, justification).

- **Naive:** No instruction to cite anything; the model may optionally reference a technique.
- **Text-grounded:** The model is explicitly instructed to cite a specific CVE or CAPEC ID from its own knowledge when it believes the traffic is malicious, and told not to say it doesn't know.
- **Retrieval-augmented (RAG):** The prompt includes the full text of real, MITRE/NVD-verified reference entries retrieved from our corpus (Section 3.4), and the model is instructed to cite only from the provided material, responding “N/A” if none of the provided entries apply.

Because DDoS/fragmentation flooding techniques are attack *patterns* rather than single-vulnerability exploits, we ground those classes against MITRE CAPEC entries; the two Mirai propagation-phase device-compromise CVEs (CVE-2016-10401, CVE-2017-17215) are reserved for the three Mirai flood classes in our corpus, since Mirai's flood traffic itself is generated post-compromise via the same technique as the generic UDP/GRE floods, while the compromise phase is where a specific vulnerability is the more natural unit of grounding.

3.4 Reference Corpus

Our RAG/text-grounding reference corpus (`cve_corpus.json`) contains reference entries independently verified against `capec.mitre.org` and `nvd.nist.gov` before this run: CAPEC-482 (TCP Flood), CAPEC-469 and CAPEC-488 (HTTP DoS/Flood), CAPEC-486 (UDP Flood), CAPEC-487 (ICMP Flood), CAPEC-495 (UDP Fragmentation), CAPEC-125 (Flooding, used explicitly as an honest generic fallback where no more specific CAPEC entry exists — e.g., for GRE-based Mirai floods and several fragmentation/flag-manipulation variants, since no dedicated CAPEC entry for these techniques exists), CVE-2016-10401, and CVE-2017-17215 — 15 of 34 classes are covered. Coverage is deliberately honest rather than exhaustive: reconnaissance, web-application, brute-force, and spoofing classes were not included in the corpus used for the RAG/text-grounding prompts in this run, so RAG-condition citations for those classes correctly show as “no matching reference” (N/A) rather than being force-fit to an unrelated entry (Section 4.2).

During this drafting session, as part of manually auditing the model's naive- and text-grounded-condition citations for classes *outside* the corpus, we additionally verified 13 further CAPEC IDs the model cited on its own initiative: CAPEC-66 (SQL Injection), CAPEC-63 (Cross-Site Scripting), CAPEC-300 (Port Scanning), CAPEC-88 (OS Command Injection), CAPEC-94 (Adversary-in-the-Middle), CAPEC-292 (Host Discovery), CAPEC-112 (Brute Force), CAPEC-169 (Footprinting, generic parent), and — critically, as *negative* examples of wrong-family citation — CAPEC-130 (Excessive Allocation), CAPEC-98 (Phishing), CAPEC-230 (Serialized Data with Nested Payloads), CAPEC-530 (Provide Counterfeit Component), and

CAPEC-666 (BlueSmacking). All 13 are real MITRE entries. This expands our verified-reference set to 21 total IDs and is reflected in the refined citation-quality breakdown in Section 4.2, but a residual $\sim 28\text{--}30$ citations per ungrounded condition remain unverified and are reported as such rather than assumed correct or fabricated.

3.5 Citation-Quality / Hallucination Scoring

For every response that cites a reference ID on an attack sample, we assign one of five grades: **fabricated** (ID does not exist against MITRE/NVD — not observed anywhere in this run, across 21 independently checked IDs), **real-but-generic** (real ID, but the broad parent category rather than the specific technique, e.g., citing CAPEC-125 “Flooding” or CAPEC-169 “Footprinting” instead of a specific child pattern), **real-but-wrong-family** (real, specific ID, but does not match the true attack class — including cases where the cited ID’s actual MITRE description is unrelated to the justification text the model wrote, e.g., citing CAPEC-98 “Phishing” while writing a justification about “TCP flag manipulation,” which is not what CAPEC-98 describes), **real-and-correct** (real, specific, and matching), and **not yet independently verified** (used only for the residual set of naive/text-grounded citations this drafting pass did not have time to check individually; explicitly not counted as either correct or fabricated).

3.6 Baseline Detectors

We implement two classical anomaly detectors as a point of comparison, trained only on held-out Benign rows (5,000 rows sampled from the full Benign file, excluded from the test pool) to reflect a realistic “learn normal, flag deviation” deployment:

- **Rolling z-score:** per-feature z-score against the benign training distribution; a window is flagged if any feature’s absolute z-score exceeds 4.0.
- **Isolation Forest** [Liu et al., 2008]: a 200-tree ensemble fit on the same benign training rows, contamination parameter 0.05.

Both are evaluated as binary detectors (attack vs. benign) on the full 1,360-sample pool ($40/\text{class} \times 34$ classes), since neither method natively performs multi-class attack-type identification — a capability gap we treat as a substantive point of comparison, not an oversight in our baseline design.

4 Results

4.1 Classification Accuracy

Condition	Accuracy	Correct / Total
Naive	99.4%	169/170
Text-grounded	98.8%	168/170
RAG-grounded	100%	170/170

Table 1: Overall classification accuracy by condition.

Accuracy is uniformly high across all 34 classes and all three conditions. Every observed miss was not a genuine misclassification but a data-parsing artifact — three of 510 responses (0.6%) were truncated to a single character ("C") in the raw API response before reaching our parser, most likely a harness-side streaming/response-handling issue rather than a model reasoning failure, and are conservatively scored as

incorrect. This should be re-investigated before submission (**[VERIFY]** root-cause the truncation artifact), but at 0.6% of calls it does not affect the paper’s substantive conclusions.

Category	Naive	Text-grounded	RAG-grounded
Benign	100%	100%	100%
Flood (DDoS/DoS)	100%	96.7%	100%
Fragmentation	93.3%	100%	100%
Mirai	100%	100%	100%
Recon	100%	100%	100%
Web/App-layer	100%	100%	100%
Spoofing/MITM	100%	100%	100%
Brute Force	100%	100%	100%

Table 2: Classification accuracy by attack category and condition (excludes the 3 parsing-artifact rows).

Classification accuracy is essentially saturated at this sample size — the interesting signal in this study is not in accuracy but in citation quality, to which we turn next.

4.2 Citation Quality

As automatically graded against our pre-existing 15-class reference corpus (matches the exact grading logic used during the experiment run):

Condition	Correct	Generic	Wrong-family	Unverified	No-citation	N/A-benign
Naive	28	34	15	86	2	5
Text-grounded	23	27	27	86	2	5
RAG-grounded	55	11	31	0	68	5

Table 3: Citation quality, automated grading against the original 15-class corpus (out of 170 responses per condition).

The large “unverified” bucket in the naive and text-grounded conditions reflects corpus-coverage gaps, not confirmed hallucination — our 15-class reference corpus does not cover reconnaissance, web-application, brute-force, or spoofing classes, so any citation the model made for those classes (correct or not) was automatically bucketed as “unverified” by the grading script. We manually resolved most of this bucket during this drafting session (Section 3.4):

Condition	Correct	Generic	Wrong-family	Still unverified	No-citation	N/A-benign
Naive	60	39	36	28	2	5
Text-grounded	53	31	49	30	2	5
RAG-grounded	55	11	31	0	68	5

Table 4: Refined citation quality after manually verifying 13 additional reference IDs.

Three findings stand out:

1. Zero fabricated identifiers, across every condition and every reference ID we checked (21 total). Even in the fully ungrounded naive condition, the model never invented a nonexistent CAPEC or CVE number. When it cited a class outside our corpus’s coverage — SQL injection, XSS, command injection,

port scanning, host discovery, ARP spoofing, brute force — it did so *consistently*: the same reference ID was cited on 5/5 samples for nine of the fourteen originally-uncovered classes (e.g., CAPEC-66 for every `SqlInjection` sample, CAPEC-63 for every `XSS` sample, CAPEC-300 for every `Recon-PortScan` sample), and every one of these turned out to be the correct, real MITRE entry. This consistency is itself evidence against random fabrication: a model guessing plausible-sounding but fake IDs would not be expected to converge on the same specific number across independent samples.

2. Where the model does fail, it fails by misattributing real reference material to the wrong technique — not by inventing IDs. The clearest example: for `DDoS-RSTFINFLOOD` (an RST/FIN TCP flag flood) in the naive condition, the model cited CAPEC-98 with the justification “matching CAPEC-98 (Phantom Resource Consumption via TCP flag manipulation).” CAPEC-98’s real MITRE title and description is “Phishing” — an entirely unrelated social-engineering attack pattern with no connection to TCP flags or resource consumption. The ID is real; the description attached to it is fabricated. We observed four more instances of this exact failure mode: CAPEC-130 (“Excessive Allocation,” whose own MITRE description explicitly *excludes* flooding — “this attack does not attempt to force this allocation through a large number of requests; that would be Flooding” — cited nonetheless for fragmentation floods), CAPEC-230 (“Serialized Data with Nested Payloads,” an XML/data-parser attack, cited for ICMP fragmentation), CAPEC-530 (“Provide Counterfeit Component,” a hardware supply-chain attack, cited for ACK fragmentation), and CAPEC-666 (“BlueSmacking,” a real flooding pattern but for Bluetooth L2CAP, not IP traffic, cited for ACK fragmentation). All five are real, verifiable MITRE entries; none of their actual descriptions support the classification they were attached to. We propose this as a fifth citation-quality category for future hallucination taxonomies — **real ID, fabricated justification** — distinct from both “fabrication” (inventing an ID) and simple “wrong-family” (citing a correct-domain but imprecise real entry).

3. RAG grounding’s main measured effect is suppressing out-of-scope citation, not just improving accuracy on covered classes. 68 of 170 RAG-condition responses (40%) — none of them benign — returned “N/A” rather than a citation. This is expected and desired behavior: our RAG corpus covers only 15 of 34 classes, and the prompt explicitly instructs the model to cite only from the provided material. Rather than reaching into its own (evidently substantial) parametric knowledge of CAPEC/CVE identifiers, as it did in the naive and text-grounded conditions, the model consistently declined to cite when the retrieved material did not apply. This is a stronger and more directly actionable safety property for a production CTI system than citation accuracy alone: a system that cites nothing rather than guessing, when it lacks grounding, is safer to deploy than one that always produces a plausible-sounding answer. RAG grounding did not eliminate wrong-family citation entirely (31/170, 18%) — even within the 7 provided reference entries, the model sometimes chose the wrong one — but it eliminated the “real ID, fabricated justification” failure mode entirely, since every RAG citation is drawn from a closed, pre-verified set.

4.3 Baseline Detector Comparison

Overall ($n=40/\text{class}$, 1,360 samples; note this is at a different sample size than the LLM results above — Section 5):

Method	Accuracy	Precision	Recall	F1
Rolling z-score	30%	100%	28%	43%
Isolation Forest	59%	100%	58%	73%

Table 5: Overall baseline detector performance (binary attack-vs-benign).

Both baselines have perfect or near-perfect precision (they essentially never false-alarm on benign traffic) but their recall collapses when evaluated across the full 34-class taxonomy rather than DDoS-only traffic,

as our earlier 3-class pilot had used. Breaking recall down by attack category reveals why:

Category	n	Z-score recall	Isolation Forest recall
Flood (DDoS/DoS)	480	56.7%	97.5%
Mirai	120	0.8%	100%
Fragmentation	120	4.2%	69.2%
DDoS-SlowLoris (“Other”)	40	25.0%	47.5%
Recon	160	31.3%	31.9%
Spoofing/MITM	80	8.8%	17.5%
Brute Force	40	2.5%	2.5%
Web/App-layer	280	7.1%	3.6%

Table 6: Baseline detector recall by attack category.

Isolation Forest is near-perfect on volumetric flood and Mirai traffic — attacks that produce a large, statistically obvious deviation in packet rate and protocol mix — but its recall falls to single digits on web-application attacks (SQL injection, XSS, command injection, browser hijacking, malware upload) and brute force, and to under 20% on spoofing/MITM. These are precisely the attack categories where the underlying traffic looks statistically closer to benign flows at the level of the 13 flow features used here (rate, TCP flags, protocol mix, packet size) — a single crafted login attempt or injected SQL string does not perturb aggregate flow statistics the way a flood does. The rolling z-score detector, additionally handicapped by a heavy-tailed Rate feature in the benign training distribution (from our earlier 3-class pilot: std = 36,680 pkt/s against a mean of 4,248 pkt/s), performs even worse across the board, including a near-total failure on Mirai traffic (0.8% recall) despite Mirai floods being visually obvious in our own visualizations.

By contrast, the LLM correctly *classifies* (not merely detects) samples from every one of these categories at $\geq 96.7\%$ accuracy in every condition (Table 1), including the categories where both classical baselines are weakest. This is the paper’s central empirical contrast: statistical anomaly detection and multimodal LLM classification are not competing on the same axis. The baselines are competitive with (or, on Mirai and flood traffic, exceed in raw binary recall terms) the LLM specifically on the attack types that were already easiest to detect statistically; they fail on exactly the attack types where the LLM’s zero-shot classification and citation-grounded explanation are the most valuable — and the latter is where hallucination risk is also most consequential, since these are the attack types least likely to be covered by any hand-built reference corpus.

5 Discussion

The LLM’s advantage is multi-class identification across attack categories a statistical baseline cannot detect, not raw binary accuracy on the categories it can. Section 3.6 shows this directly: Isolation Forest’s recall ranges from 100% (Mirai) to 2.5% (brute force) depending on attack category, while the LLM’s classification accuracy is uniformly high across all categories in all three conditions. A paper (or deployed system) evaluated only on DDoS/flood traffic, as our earlier 3-class pilot was, would substantially overstate how competitive classical baselines are with LLM-based classification once the full attack taxonomy is considered.

Hallucination in this task manifests as misattribution, not fabrication. This refines rather than confirms the framing carried over from the general LLM-CTI-hallucination literature, which documents high *fabrication* rates for CVEs, particularly those disclosed after a model’s training cutoff [VERIFY] citation, HalluCVE. Across 21 independently verified reference IDs spanning all three conditions, we found zero

cases of an invented CAPEC or CVE number — but we found five clear cases of a real ID paired with a materially incorrect description of what that ID actually means (Section 4.2, finding 2). A plausible explanation is that well-documented, decades-old, high-traffic CAPEC entries (flooding patterns, injection attacks, reconnaissance techniques) are extremely stable in a model’s parametric memory as *identifiers*, even when the model’s recall of the *specific content* behind a less-salient or less-frequently-cited identifier (e.g., CAPEC-98, CAPEC-130) is unreliable. This is a distinct and, for a production CTI system, arguably more dangerous failure mode than outright fabrication: a fabricated ID is trivially falsifiable by anyone who looks it up, while a real ID with a plausible-sounding but wrong description is not.

Retrieval grounding’s most important measured effect is scope discipline, not just accuracy. The 40% “no-citation” rate under RAG grounding (Section 4.2, finding 3) is, on reflection, the single most actionable result in this study for anyone building an LLM-assisted CTI or intrusion-explanation system: a model that is told to ground its citations in retrieved material, and complies by declining to cite when that material doesn’t apply, is exhibiting exactly the behavior a safety-conscious deployment needs. This suggests that the practical mitigation for citation hallucination in this setting is not primarily “give the model a bigger reference corpus so it always has something to cite” but “constrain the model to cite only from what it was given, and treat ‘no citation’ as a valid and expected output” — a design implication that is different from, and arguably more important than, the accuracy-uplift framing RAG is usually presented with.

Limitations.

1. LLM results are at $n=5$ /class (170 samples), while baseline results are at $n=40$ /class (1,360 samples) — not currently a matched- N comparison; the accuracy and per-category patterns reported here should be read as suggestive rather than statistically definitive until this is resolved.
2. A residual 28 (naive) and 30 (text-grounded) citations per condition remain individually unverified against MITRE/NVD as of this draft; we have strong indirect evidence (citation consistency across independent samples, and that 13/13 additional IDs checked were real) that most of these are likely correct-but-uncovered rather than fabricated, but this is an inference, not a completed audit.
3. Our reference corpus covers 15 of 34 classes for RAG/text-grounding; reconnaissance, web-application, brute-force, and spoofing classes have no grounding material in the current corpus.
4. Only one multimodal LLM (Claude Sonnet 5) was evaluated; whether the “no fabrication observed” finding generalizes to other models is untested.
5. Three of 510 API responses (0.6%) were truncated to a single character before parsing, a data-quality artifact not yet root-caused.
6. The visualization method (4-panel flow-feature time series) is a documented deviation from the IP-based scatter plots used in prior work, driven by the CIC-IoT-2023 CSV export’s lack of IP fields.

6 Future Work

Complete individual MITRE/NVD verification of the remaining ~ 28 – 30 unverified citations per ungrounded condition; scale the LLM harness to $n=40$ /class for a matched- N comparison against the baselines; expand the reference corpus to cover the remaining 19 uncovered classes using the newly-verified IDs from this session (CAPEC-66, 63, 300, 88, 94, 292, 112, 169) plus further verification of the less-consistent citations (e.g., Backdoor_Malware, BrowserHijacking, DNS_Spoofing) and re-run the RAG condition against the expanded corpus to test whether “no-citation” rates drop correspondingly; evaluate additional multimodal models (e.g., GPT-4o, Gemini) to test whether the “misattribution, not fabrication” finding is specific to the model tested; and formally define and measure the proposed fifth citation-quality category — real ID, fabricated justification — as a named category in future hallucination benchmarks rather than folding it into “wrong-family.”

7 Conclusion

Zero-shot multimodal classification of IoT-botnet traffic achieves high accuracy across all 34 attack classes in the CIC-IoT-2023 taxonomy, in every prompting condition tested, including attack categories where classical statistical anomaly detectors (rolling z-score, Isolation Forest) achieve near-zero recall. On the citation-hallucination question motivating this study, we find that reference-ID fabrication is not the dominant failure mode for this model on this task — across 21 independently verified reference IDs, none were invented — but that ungrounded prompting still produces materially incorrect technical explanations through misattribution of real reference material, and that retrieval-augmented grounding’s primary benefit is not merely more accurate citations but a measurable, desirable tendency to decline citation entirely when the retrieved evidence does not support one. These findings suggest that hallucination-mitigation efforts for LLM-based cyber threat intelligence should evaluate and design for citation *scope discipline*, not only citation *existence*.

Ethics / Broader Impact Statement

This work uses a public, IRB-exempt research dataset (CIC-IoT-2023) and does not involve human subjects. All CVE/CAPEC references discussed as “verified” in this paper were independently checked against nvd.nist.gov or capec.mitre.org rather than taken on the LLM’s word, including in cases where the paper itself is analyzing LLM-generated citations — this is a load-bearing methodological commitment given the paper’s subject matter, and we have flagged every reference we did not have time to individually verify as such rather than assuming correctness. **[PLACEHOLDER: expand before submission with a statement on responsible disclosure norms and dual-use considerations for a paper that documents specific attack-pattern/traffic-signature correspondences.]**

Use of Generative AI

This paper’s experiments, analysis code, and this draft were produced with substantial assistance from Claude (Anthropic), including as the subject model under evaluation. All factual claims about MITRE CAPEC and NVD CVE record content in this paper were verified against the primary source directly (not taken from the LLM’s output) as part of the research methodology itself, not merely as an AI-disclosure formality. **[PLACEHOLDER: expand per the eventual target venue’s AI-disclosure policy — see AISec 2026’s requirements as a model for what this paragraph should contain.]**

References

- [Antonakakis et al., 2017] Antonakakis, M., April, T., Bailey, M., Bernhard, M., Bursztein, E., Cochran, J., Durumeric, Z., Halderman, J. A., Invernizzi, L., Kallitsis, M., Kumar, D., Lever, C., Ma, Z., Mason, J., Menscher, D., Seaman, C., Sullivan, N., Thomas, K., & Zhou, Y. (2017). Understanding the Mirai botnet. In *Proceedings of the 26th USENIX Security Symposium* (pp. 1093–1110). USENIX Association.
- [Kolias et al., 2017] Kolias, C., Kambourakis, G., Stavrou, A., & Voas, J. (2017). DDoS in the IoT: Mirai and other botnets. *Computer*, 50(7), 80–84.
- [Chandola et al., 2009] Chandola, V., Banerjee, A., & Kumar, V. (2009). Anomaly detection: A survey. *ACM Computing Surveys*, 41(3), 1–58.
- [Neto et al., 2023] **[VERIFY]** Neto, E. C. P., Dadkhah, S., Ferreira, R., Zohourian, A., Lu, R., & Ghorbani, A. A. (2023). CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT

environment. *Sensors*. (Full volume/issue/page numbers to be confirmed against the published version before submission.)

[NetFlow-Viz IEEE paper] **[VERIFY]** “Multimodal LLMs for Zero-Shot Intrusion Detection Using Net-Flow Visualisations.” IEEE. (Full author list, conference name, year, and page numbers to be confirmed — found via search at ieeexplore.ieee.org/document/11146352/; not yet independently fetched and verified in full.)

[HalluCVE] **[VERIFY]** “HalluCVE: A Multi-Signal Benchmark for Hallucination Detection in LLM-Generated Cyber Threat Intelligence.” (Full author list and complete venue details to be confirmed — found via search at ph01.tci-thaijo.org.)

[ProveRAG] **[VERIFY]** “ProveRAG: Provenance-Driven Vulnerability Analysis with Automated Retrieval-Augmented LLMs.” arXiv:2410.17406. (Full author list to be confirmed.)

[Liu et al., 2008] **[VERIFY]** Liu, F. T., Ting, K. M., & Zhou, Z.-H. (2008). Isolation Forest. In *Proceedings of the 8th IEEE International Conference on Data Mining*. (Citation stated from general knowledge, not independently re-verified in this conversation — confirm before submission.)

[MITRE CAPEC] MITRE CAPEC (all independently fetched and verified against capec.mitre.org during this study). Reference-corpus entries: CAPEC-125 (Flooding), CAPEC-469 (HTTP DoS), CAPEC-482 (TCP Flood), CAPEC-486 (UDP Flood), CAPEC-487 (ICMP Flood), CAPEC-488 (HTTP Flood), CAPEC-495 (UDP Fragmentation). Additional IDs verified during citation audit: CAPEC-63 (Cross-Site Scripting), CAPEC-66 (SQL Injection), CAPEC-88 (OS Command Injection), CAPEC-94 (Adversary in the Middle), CAPEC-98 (Phishing), CAPEC-112 (Brute Force), CAPEC-130 (Excessive Allocation), CAPEC-169 (Footprinting), CAPEC-230 (Serialized Data with Nested Payloads), CAPEC-292 (Host Discovery), CAPEC-300 (Port Scanning), CAPEC-530 (Provide Counterfeit Component), CAPEC-666 (BlueSmacking).

[NVD] NVD. CVE-2016-10401; CVE-2017-17215. Retrieved from nvd.nist.gov.